EWB Cybersecurity Assessment 01: Security Foundations

Name: Karthik K | **Batch/Group:** [your batch] | **Issued:** 18 October 2026

Task A: Secure Mira's account

Risk	Asset	CIA impact	Control	Limitation
Same short password on email and portal	Email and portal accounts	**C, I**: one leaked or guessed password opens both accounts, so an attacker can read and change data	Unique long passphrase per account, kept in a password manager	The manager's master password becomes a single point of failure, and Mira has to actually use it
Approving unexpected sign-in prompts	Account session	**C, I**: an attacker with the password gets in once she taps "approve"	Deny and report unexpected prompts; use number-matching MFA	Doesn't help if she is tricked into approving a prompt that looks legitimate
Postponed device updates	Laptop and OS	**C, I, A**: known vulnerabilities stay open to malware or ransomware	Turn on automatic updates	Doesn't stop unknown (zero-day) flaws, and restarts are still needed
Only one copy of the project	Project files	**A** (and **I** if the file is corrupted): loss, theft or failure destroys the work	Keep a second copy in cloud storage plus an external drive	Synced copies can also be overwritten or corrupted, so restores should be tested
Friend uses the laptop under Mira's signed-in account	Her accounts and files	**C, I**: the friend can read, change or delete her data	Lock the screen when away and give the friend a separate guest account	Doesn't stop a determined person with physical access, and relies on Mira's habits

Priorities

1 **Unique passwords.** One reused password exposes both accounts, and this is the most likely route in.

2 **Handle MFA prompts safely.** It's the last barrier once the password is known.

3 **Stop shared signed-in use.** It gives direct access with no attack needed.

Updates and backups come next. They matter, but they reduce the impact or likelihood of a less immediate threat.

A3. Authentication vs authorisation

Authentication proves who you are. When Mira logs into the learning portal with her password and MFA, the portal confirms she is Mira. Authorisation decides what she can do afterwards. She can view her own courses and submit her own work, but she can't edit other students' grades or access admin settings.

Task B: Suspicious message

B1. Warning signs

Phrase	Why it needs scrutiny
"campus-awards.example"	The college normally uses *campus.example*. This is a look-alike domain
"Reply-To: help@personal-awards.example"	Replies go to a different domain from the sender, so they could reach someone else
"expires in 20 minutes"	Artificial urgency pushes people to act before thinking
"enter your college password and OTP"	Legitimate services don't ask for passwords and one-time codes through a link. This is credential harvesting

Phrase	Why it needs scrutiny
"Do not contact the college office"	Isolates the victim from the one place that could confirm or deny the claim

A sixth sign is "photo of your identity card", a request for sensitive identity data.

B2. Safe verification

1 Don't click anything in the message.

2 Open the official college portal by typing the address yourself, or use a phone number or email from the college website or notice board.

3 Ask the scholarship office whether the award exists.

HTTPS only means the connection is encrypted, and any site, including a malicious one, can have it. A display name like "Scholarship Desk" is text the sender chooses, so neither proves who sent the message.

B3. Response plan (password and OTP already entered)

1 From a trusted device, go to the official site and change the password immediately. Don't use the message's link.

2 Sign out of all sessions and review MFA methods and recovery details.

3 Change the password anywhere else it was reused.

4 Report to the college IT/helpdesk through an official contact, and tell the office if an ID photo was sent.

5 Follow-up: check recent sign-in history, mailbox forwarding rules and connected devices. Watch for more phishing. Never send the password or OTP to anyone.

B4. What can't be established

Whether the sender is actually malicious, or whether the scholarship is real. Helpful evidence includes confirmation from the college office, the full email headers (SPF/DKIM/DMARC results), and the college's official list of domains.

Task C: Sign-in alert

C1. Timeline

1 **09:00-09:01, observed:** Password success and MFA approved from 192.0.2.10, the usual classroom IP. *Interpretation:* normal activity, consistent with the student's statement that they didn't sign in after 09:05.

2 **10:14-10:16, observed:** From 198.51.100.23, two failed passwords then a success within three minutes. *Interpretation:* possible guessing or prior knowledge of the password. This isn't proven.

3 **10:17-10:18, observed:** MFA denied, then approved. The student says they approved a prompt around 10:18 to stop the repeated requests. *Interpretation:* resembles MFA fatigue, but we can't tell from the log who denied the first prompt.

4 **10:20, observed:** A session was created from the new IP. *Interpretation:* likely unauthorised, given the student says they didn't sign in.

C2. Explanations

- **Likely:** Someone else had or guessed the password and triggered MFA prompts. The student approved one to stop them, which gave access.
- **Alternative:** The student, or someone they know, signed in from another network such as mobile data or a VPN, and the statement is mistaken or incomplete.

- **Checks to tell them apart:** (1) Compare the session's device, browser and location data with the student's registered devices. (2) Review what happened in the session, such as mailbox rules, downloads or password changes, and ask which network the student was on.

An IP address identifies a connection, not a person.

C3. Response actions (for the authorised IT team)

1 **Preserve evidence first (minutes only).** Export the logs and session details, and don't delete anything.

2 **Protect the account.** End the active session, reset the password, revoke tokens and review the MFA methods.

3 **Scope and harden.** Review activity during the session, check for password reuse elsewhere, and enable number-matching MFA.

C4. Incident summary

On 18 October 2026, student07's account showed two failed passwords, a successful password and an approved MFA prompt from 198.51.100.23 between 10:14 and 10:18, followed by a session at 10:20. The student says they did not sign in and approved a prompt only to stop repeated requests. This suggests possible MFA-fatigue compromise, though the actor and source remain unconfirmed. Priority: high. Next action: IT should preserve logs, end the session, reset the password, revoke MFA tokens and review account activity.

Task D: AI answer review

D1. Corrections

1 **"Safe because it uses HTTPS."** HTTPS only encrypts the connection and doesn't verify the sender. The message also has a look-alike domain, urgency and a request for credentials.

2 **"Logs prove the person using the IP stole the password."** An IP isn't an identity (shared networks, VPNs and proxies exist), and logs show events, not intent. This is unsupported certainty.

3 **"MFA prevents every account compromise."** It reduces risk but can be bypassed through prompt fatigue (Task C), OTP phishing (Task B) or stolen sessions.

4 **"Delete the suspicious logs."** That destroys the evidence needed for investigation, so logs should be preserved.

5 **"Send the password to support."** Passwords and OTPs should never be shared, and support never needs them. Reset the password through the official process.

D2. Better prompt

This is a fictional training exercise. Analyse only the synthetic evidence below, and don't assume facts about real people or systems. Give: (1) observed facts, quoted from the evidence; (2) interpretations, labelled as assumptions; (3) at least two alternative explanations; (4) extra evidence that would help; (5) your confidence and uncertainties. Do not ask for or accept passwords, OTPs, ID photos or personal data. If any appear, tell me to remove them. Don't advise deleting logs or visiting links. Evidence: [paste synthetic evidence]

D3. Corrected advice

HTTPS only shows that a connection is encrypted; it does not prove a message or website is genuine. Verify suspicious messages through an official portal or contact obtained independently, not links in the message. A sign-in from a new IP address is a lead, not proof of who acted; compare it with device, location, timing and the user's account of events. MFA greatly reduces risk but can be bypassed through prompt fatigue, OTP phishing or stolen sessions, so users should deny and report unexpected prompts. Preserve logs, never delete them. Never share passwords or OTPs with anyone, including support;

instead change the password through the official site, revoke active sessions, and report the incident to authorised IT staff.

D4. AI declaration and references

- **Declaration:** [Edit so it is true for you, e.g. "Claude was used to draft and structure answers. I reviewed, verified and rewrote them in my own words." If AI was not used, write "not used".]
- **References:** CISA, *Secure Our World* (https://www.cisa.gov/secure-our-world) supports the points on strong passwords, MFA, updates and phishing. NIST, *Generative AI Profile, AI 600-1* (https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf) supports the point that AI can confabulate, so its output needs verification.